DIGITAL FORENSICS & INCIDENT RESPONSE

Practical Investigation Report

Phishing Attack Simulation & Digital Forensic Investigation

A controlled GoPhish credential-harvesting campaign and its end-to-end forensic analysis

---

Analyst: Sagar Bidari

Home Lab — VMware Workstation (Kali Linux + Windows 11)

Report date: 27 September 2026 · Classification: TLP:CLEAR (training exercise)

1. Executive Summary

This report documents a controlled, fully authorised phishing simulation conducted end-to-end in a self-contained home lab, followed by a structured digital forensic investigation of the resulting artefacts. The exercise plays both sides of an attack: the **attacker** builds and launches a credential-harvesting campaign, and the **investigator** then preserves, analyses and correlates the evidence the attack leaves behind.

Using **GoPhish** on Kali Linux, a spoofed **Microsoft 365 "password expiry"** email was sent to a victim mailbox hosted on Proton Mail. The victim, operating a Windows 11 endpoint, opened the email, clicked the embedded link, and submitted credentials into a cloned Microsoft sign-in page hosted on the attacker's machine. The credentials were captured in plaintext, confirming a successful simulated compromise.

The forensic investigation recovered and hash-verified every artefact, and the email-header analysis produced the report's central finding: the phishing message **passed SPF, DKIM and DMARC** because it was relayed through a genuine Gmail account — demonstrating that authentication success is not a guarantee of legitimacy. Header analysis also recovered two decisive attacker indicators: the `X-Mailer: gophish` header and a `Message-ID` ending in `@kali`, both betraying the attack platform.

Key Judgements

- A spearphishing email with a deceptive link was delivered and **successfully harvested credentials** (**MITRE T1566.002**).
- The email **passed all three authentication checks** (SPF/DKIM/DMARC) via legitimate-service abuse — the key defensive lesson.
- The attack platform leaked into the headers (`X-Mailer: gophish`, `@kali` Message-ID) — strong detection opportunities.
- All five evidence items were preserved with **SHA-256 integrity hashes**; findings are fully reproducible.

Attack Outcome	Severity	Evidence Integrity
Credentials harvested	HIGH	Verified (SHA-256)

2. Introduction, Scope & Objectives

Phishing remains the most common initial-access vector in real-world intrusions. The objective of this exercise is to build practical, defensible experience in both offensive email-based social engineering and the defensive forensic response, using only infrastructure and accounts fully owned and controlled by the analyst.

Objectives

- Design and launch a realistic phishing campaign in an isolated lab using GoPhish.
- Capture the complete victim interaction chain: delivery, open, click, and credential submission.
- Conduct a structured five-stage digital forensic investigation of the resulting artefacts.
- Perform email-header forensics (SPF/DKIM/DMARC, routing, originating platform) and corroborate against live DNS.
- Produce an evidence register with integrity hashes, a correlated timeline, findings, and an incident-response plan.

Scope & Boundaries

- In scope: two lab VMs and three e-mail accounts, **all owned by the analyst**.

- Out of scope: any third-party recipient, production system, or real personal credential. Submitted credentials were deliberately fabricated lab values.

3. Authorisation & Ethical Statement

This exercise was conducted entirely within a private, isolated VMware lab on hardware owned by the analyst. Every email account involved — the attacker sender, and the victim mailbox — was created and owned by the analyst solely for this exercise. No third party was targeted, contacted, or deceived at any point. The credentials "harvested" were fictitious values (`FakePass123!`) entered by the analyst playing the victim role.

The victim role was deliberately confined to an isolated Windows 11 VM to preserve forensic integrity and avoid contaminating any production system. The purpose is strictly educational: to understand attacker tradecraft in order to defend against it. No harvested data was retained beyond what is required to evidence this report.

4. Lab Environment & Tooling

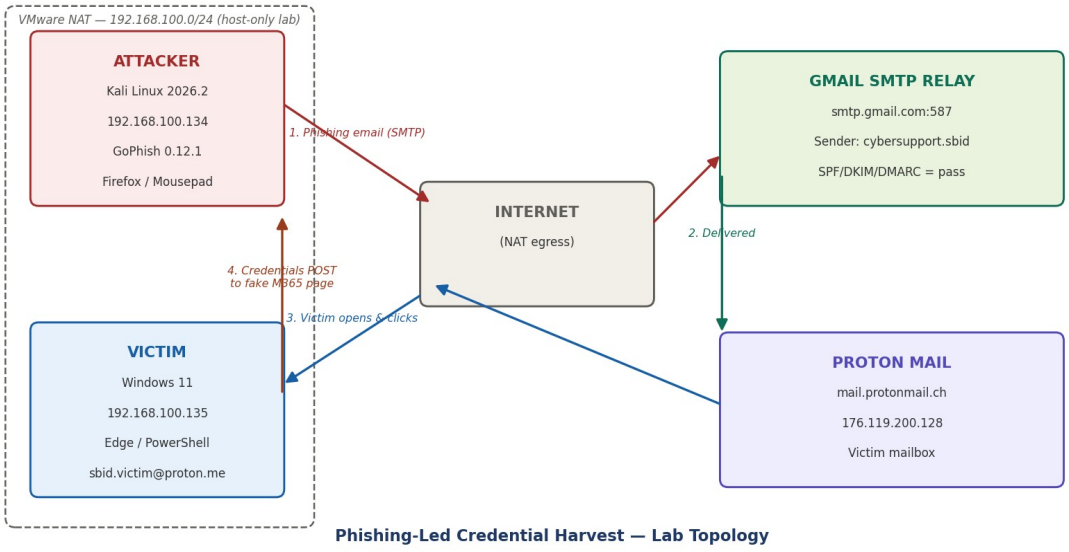


Figure 1 — Lab topology: attacker (Kali) and victim (Windows 11) on an isolated VMware NAT segment, with mail relayed via Gmail SMTP to a Proton mailbox.

Systems & Tools

Attacker host	Kali Linux 2026.2 (VMware), 192.168.100.134
Victim host	Windows 11 (VMware), 192.168.100.135
Network	VMware NAT segment 192.168.100.0/24 (host-only lab)
Phishing framework	GoPhish 0.12.1-0kali6 (admin :3333, phishing server :80)
Mail relay (sender)	Gmail SMTP smtp.gmail.com:587, app-password auth
Attacker identity	"Cyber Support" <cybersupport.sbid@gmail.com>
Victim mailbox	sbid.victim@proton.me (Proton Mail)
Forensic tools	certutil (Windows), sha256sum (Kali), MXToolbox, browser history, dig/DNS

5. Methodology — Five-Stage Forensic Process

The investigation follows a standard digital-forensics lifecycle. Each stage is evidenced later in this report:

Stage	Activity in this investigation
1. Identification	Recognise the phishing email and enumerate the artefacts it produced (email, headers, landing-page capture, host history).
2. Preservation	Export the email as .eml and compute SHA-256 hashes to lock integrity before analysis.
3. Collection	Gather the GoPhish results/timeline, captured credentials, victim browser history, and DNS/MX records.
4. Analysis	Dissect email headers (SPF/DKIM/DMARC, routing, X-Mailer), decode the delivery path, examine captured data.
5. Correlation & Reporting	Reconcile attacker-side and victim-side timelines (incl. clock skew) into one narrative and report findings.

6. Attack Simulation (Offensive Phase)

6.1 Environment preparation

Both lab hosts were confirmed on the same NAT segment (Kali `192.168.100.134`, Windows `192.168.100.135`), establishing reachability for the phishing server.



Figure 2 — Attacker host IP confirmed (Kali, 192.168.100.134).

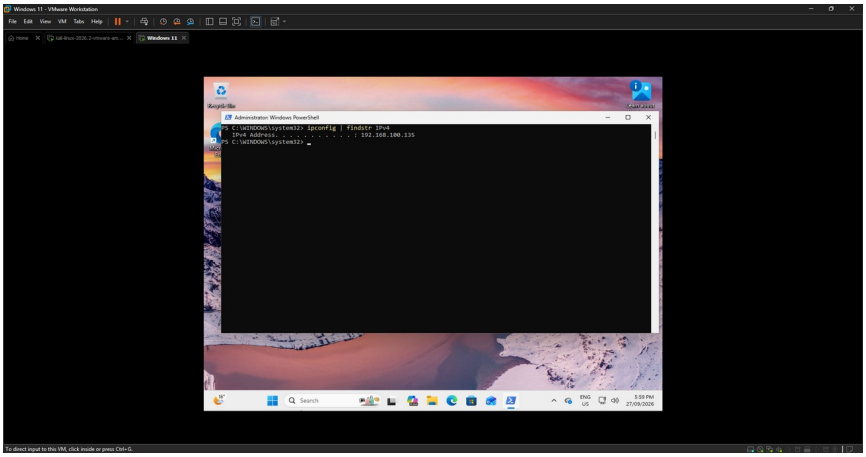


Figure 3 — Victim host IP confirmed (Windows 11, 192.168.100.135).

6.2 GoPhish installation

GoPhish was installed from the Kali package repository and started, exposing the admin console on `https://127.0.0.1:3333`.

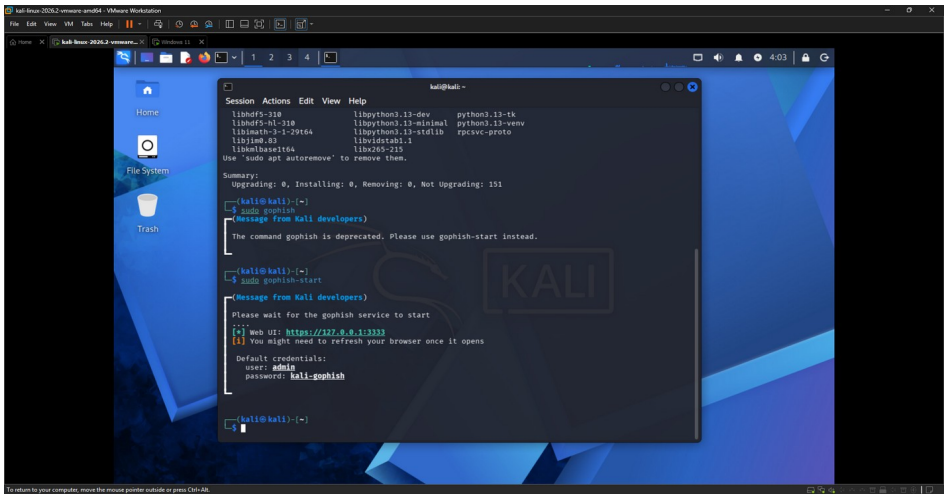


Figure 4 — GoPhish service started; admin console and default credentials.

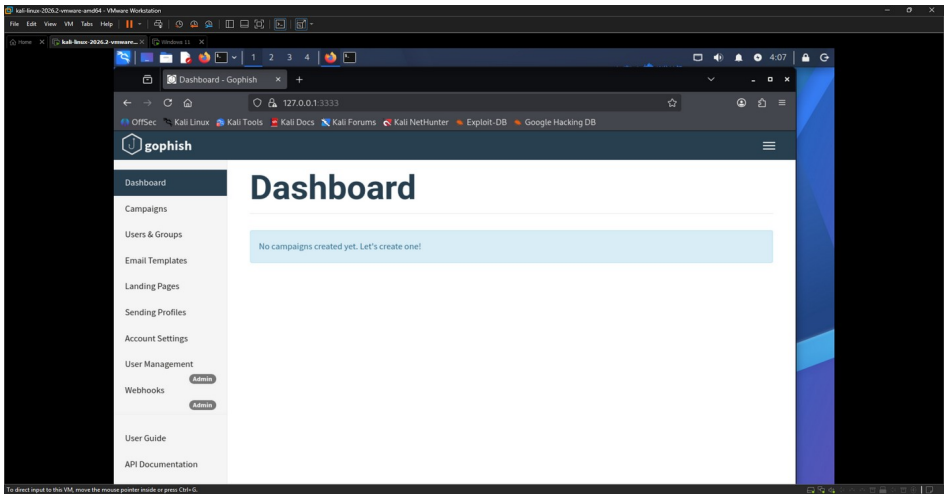


Figure 5 — GoPhish admin dashboard after authentication.

6.3 Sending profile (Gmail SMTP)

A sending profile relayed mail through Gmail's SMTP using an app password. A built-in test confirmed delivery before launch. Note: the sender's `From` address had to be correctly formatted as `Display Name <email>` to satisfy Gmail's envelope validation.

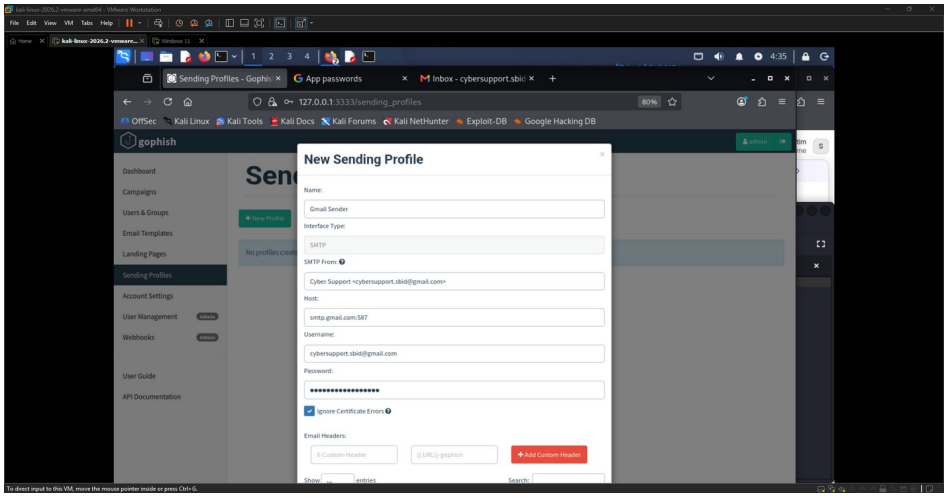


Figure 6 — Sending profile: Gmail SMTP relay with app-password authentication.

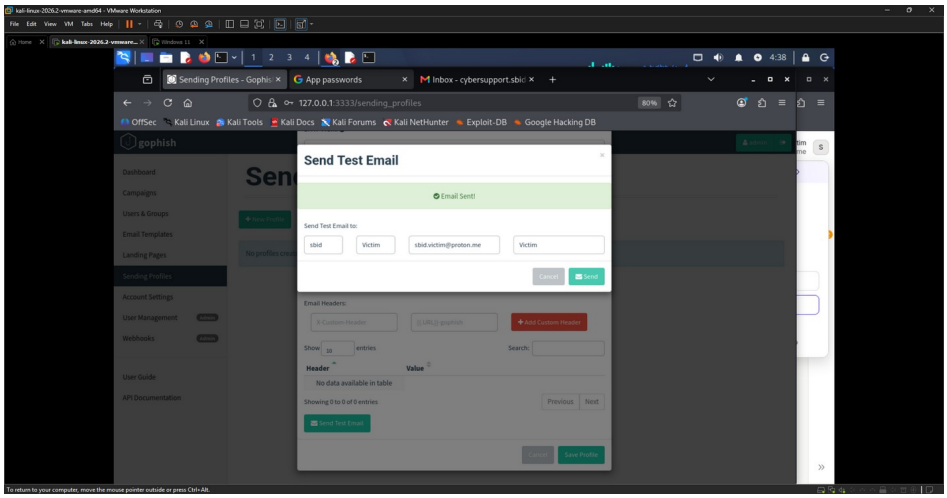


Figure 7 — Successful SMTP test (“Email Sent!”), proving the delivery path.

6.4 Landing page, email template & target

A cloned Microsoft 365 sign-in page was configured with **Capture Submitted Data** and **Capture Passwords** enabled. GoPhish warns that captured passwords are stored in cleartext — precisely why credential harvesting is so damaging.

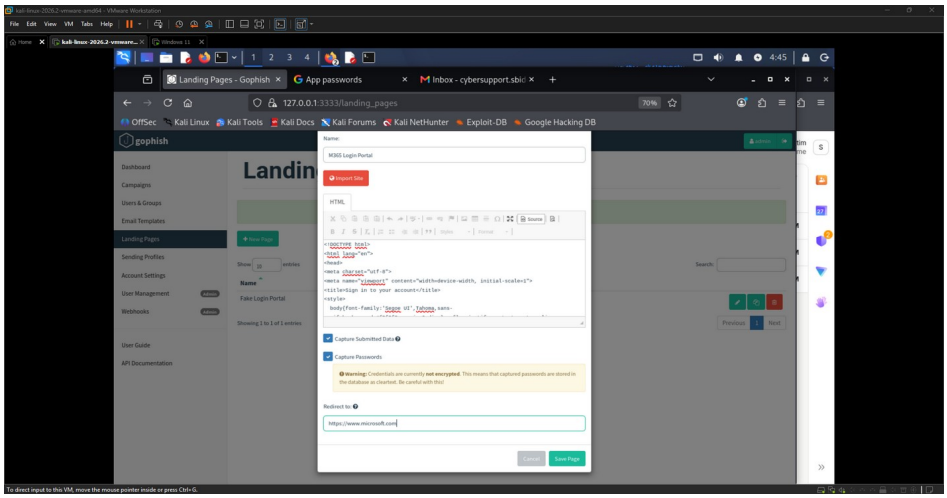


Figure 8 — Fake M365 landing page with credential capture enabled (note the cleartext-storage warning).

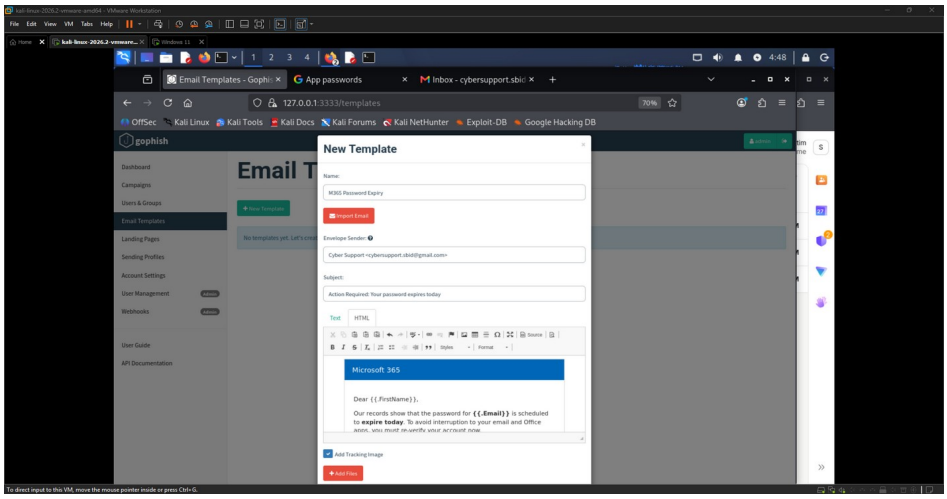


Figure 9 — Phishing email template: Microsoft 365 password-expiry lure with personalisation tokens.

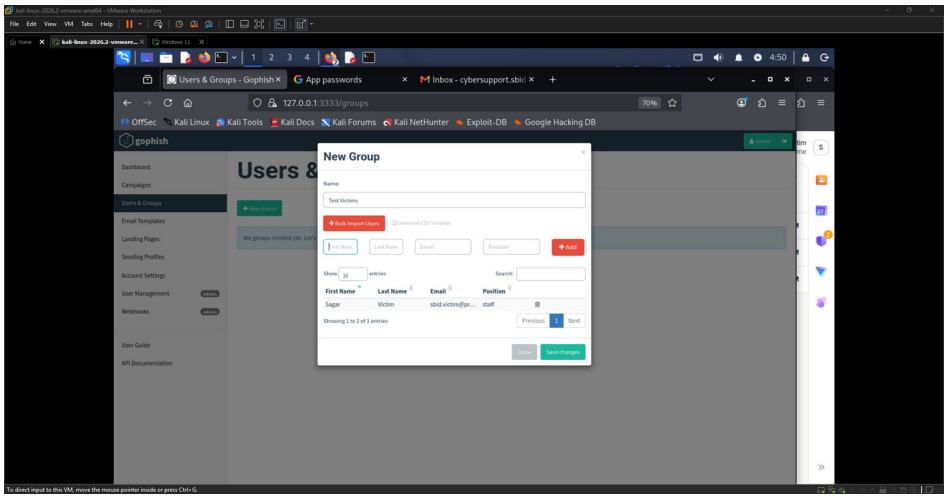


Figure 10 — Target group containing the analyst-owned victim mailbox.

6.5 Campaign launch

The campaign wired the template, landing page and sending profile together, with the phishing URL pointing at the Kali host (`http://192.168.100.134`).

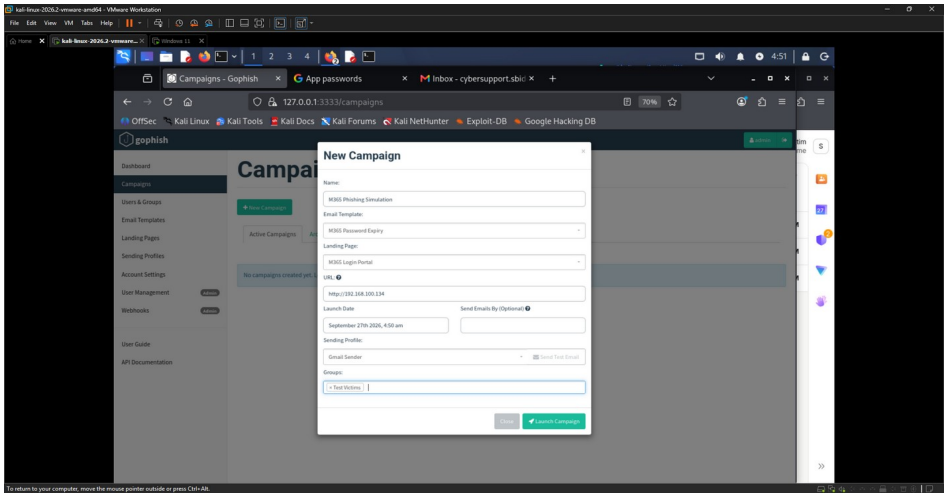


Figure 11 — Campaign configuration: link directed to the attacker-hosted landing page.

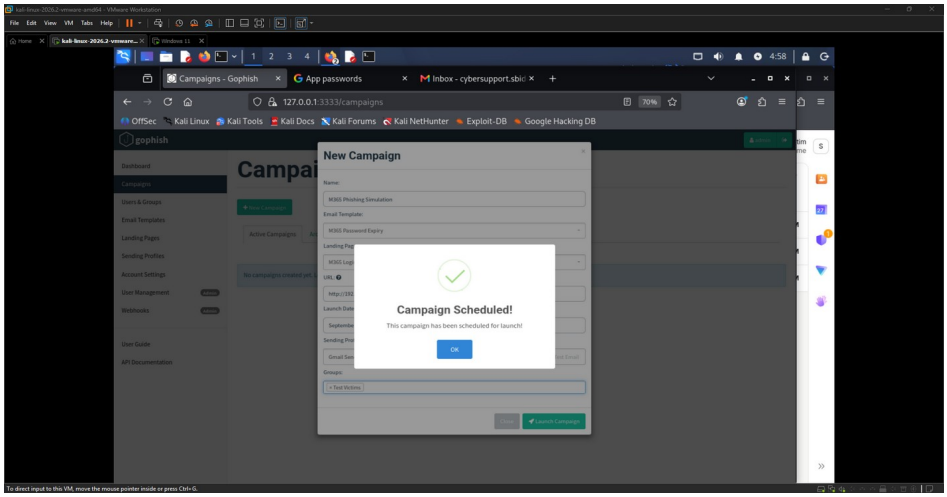


Figure 12 — Campaign scheduled and launched.

7. Victim Interaction & Credential Capture

Playing the victim on the Windows 11 endpoint, the analyst received, opened and acted on the phishing email. GoPhish recorded each stage of the funnel.

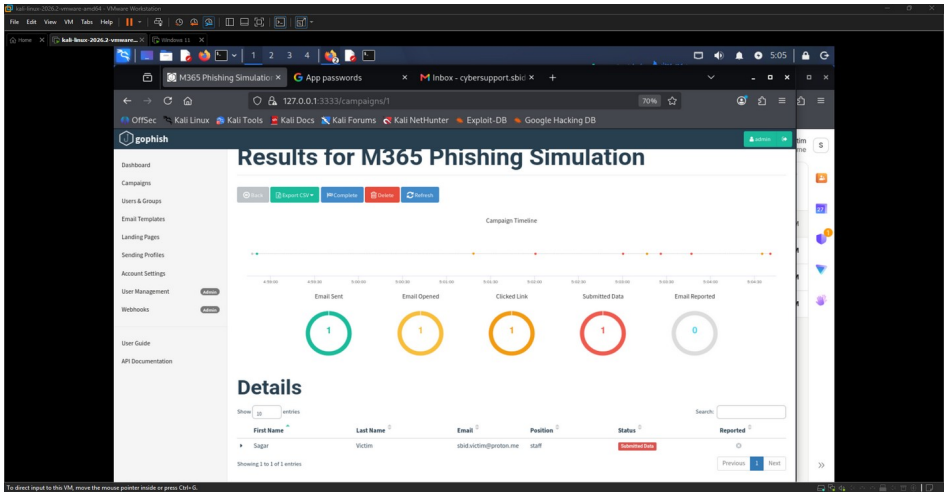


Figure 13 — Campaign funnel: 1 sent, 1 opened, 1 clicked, 1 submitted.

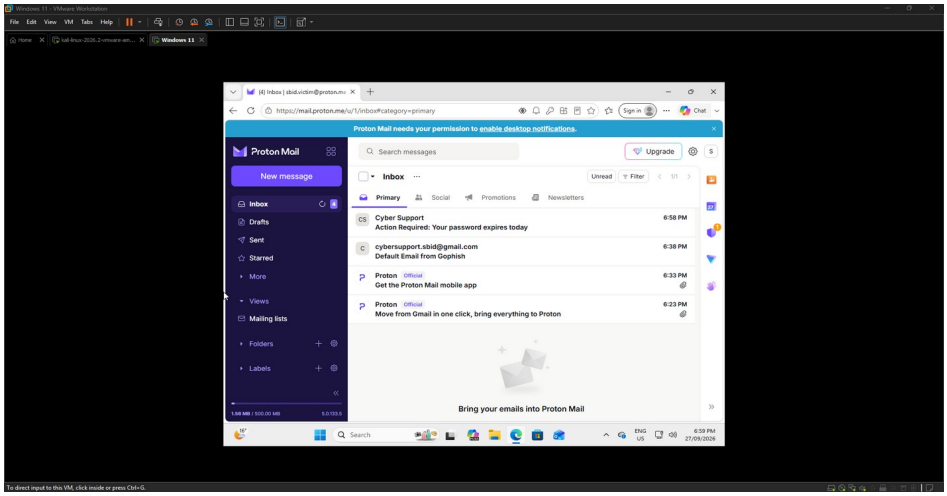


Figure 14 — Phishing email received in the Proton victim inbox ("Cyber Support — Action Required").

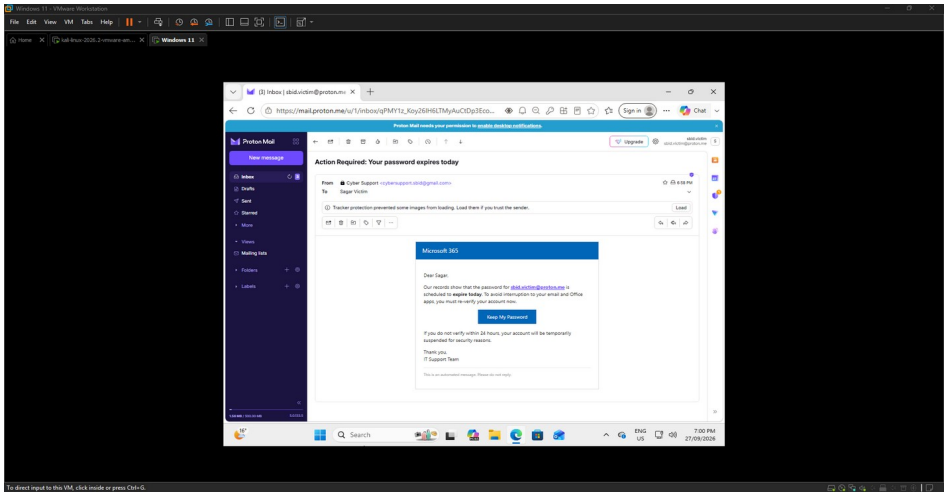


Figure 15 — Email opened on Windows 11 showing the Microsoft 365 password-expiry lure.

A decisive forensic detail: Proton's **link-confirmation dialog** exposed the true destination of the button — `http://192.168.100.134/?rid=IUH8ofC` — an internal IP masquerading behind a “Keep My Password” button. This is exactly the signal a trained user is taught to check.

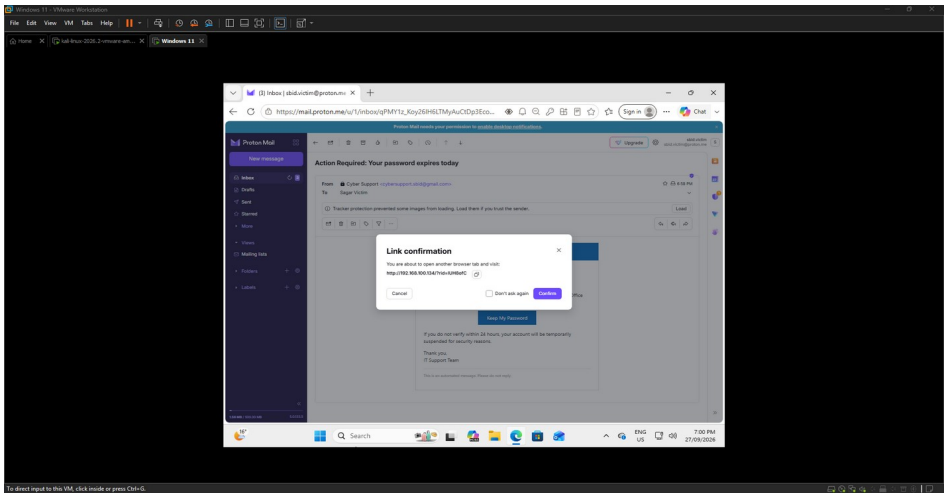


Figure 16 — Proton's link-confirmation control reveals the deceptive URL to the attacker's host.

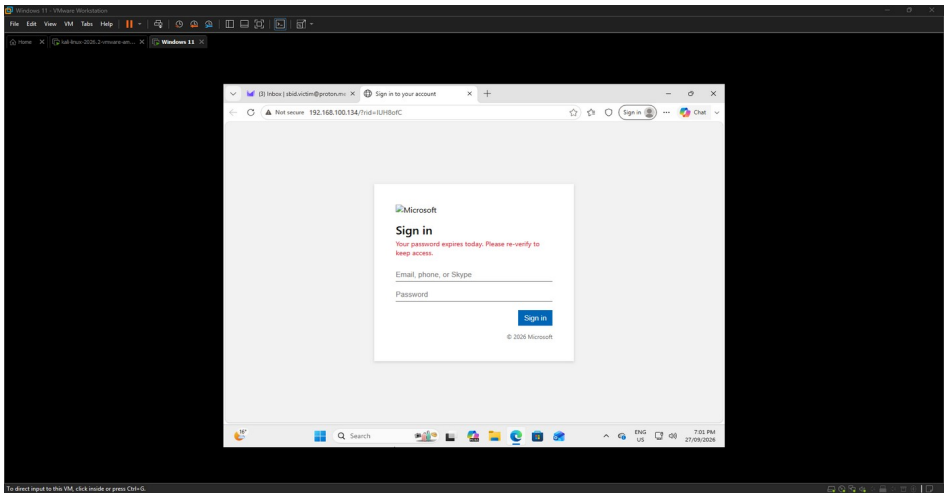


Figure 17 — Cloned Microsoft sign-in page served over HTTP (“Not secure”) from 192.168.100.134.

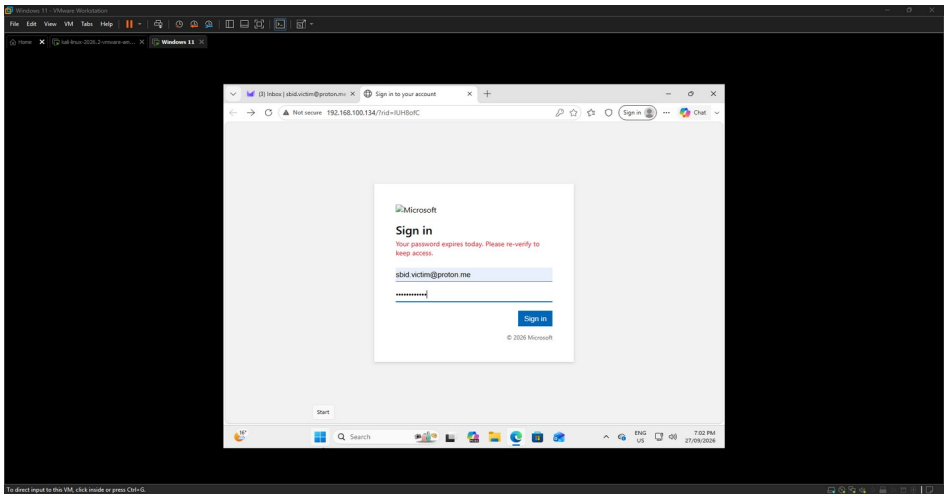


Figure 18 — Credentials entered into the fake page (fabricated lab values).

GoPhish's timeline records the full kill-chain with per-event timestamps and a device fingerprint (`Windows 10, Chrome 154`), and — critically — the **harvested credentials in plaintext**.

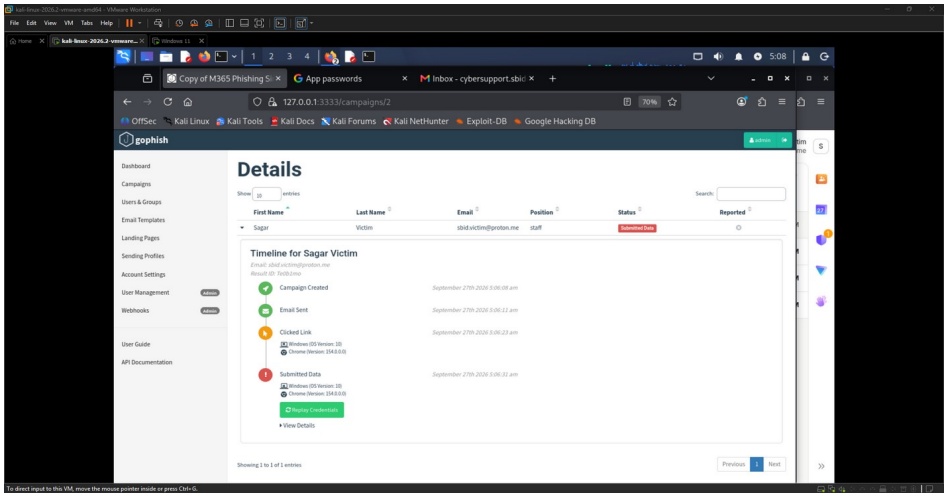


Figure 19 — GoPhish timeline: Created → Sent → Clicked → Submitted Data, with victim fingerprint.

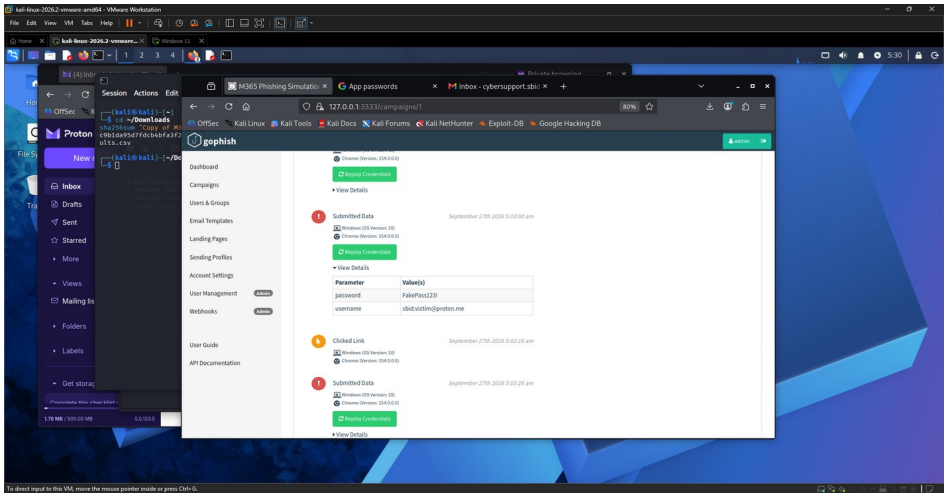


Figure 20 — Proof of harvest: captured username and password recovered in plaintext.

8. Digital Forensic Investigation

8.1 Evidence Register (with integrity hashes)

ID	Artefact	Source / Method	Integrity (SHA-256)
E1	Phishing email (.eml)	Proton export, Windows	fc6e514b…488684e (certutil)
E2	GoPhish results CSV	GoPhish export, Kali	c9b1da95…0862c (sha256sum)
E3	Captured credentials	GoPhish timeline	(within GoPhish DB — Fig 20)
E4	Victim browser history	Edge history, Windows	screenshot artefact (Fig 24)
E5	Email headers + DNS/MX	MXToolbox / live DNS	derived from E1

Each machine's native hashing tool was used — `certutil` on Windows for the `.eml`, `sha256sum` on Kali for the CSV — documenting integrity per platform.

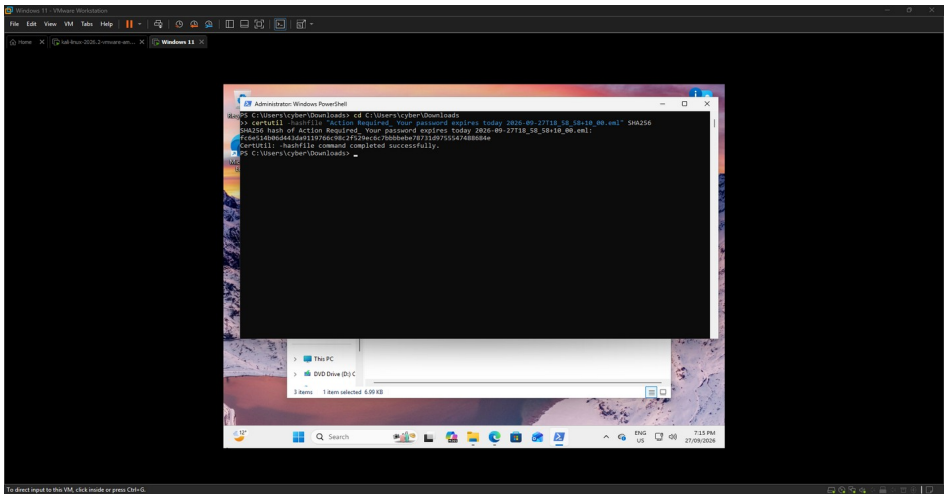


Figure 21 — SHA-256 of the exported phishing email (certutil, Windows).

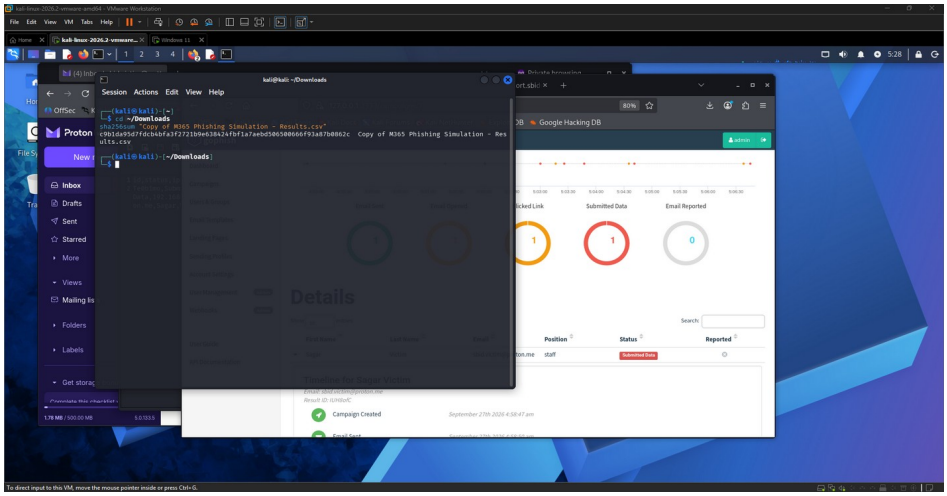


Figure 22 — SHA-256 of the GoPhish results CSV (sha256sum, Kali).

8.2 Email Header Analysis (primary finding)

The raw headers were extracted from the `.eml` and analysed. Three findings stand out.

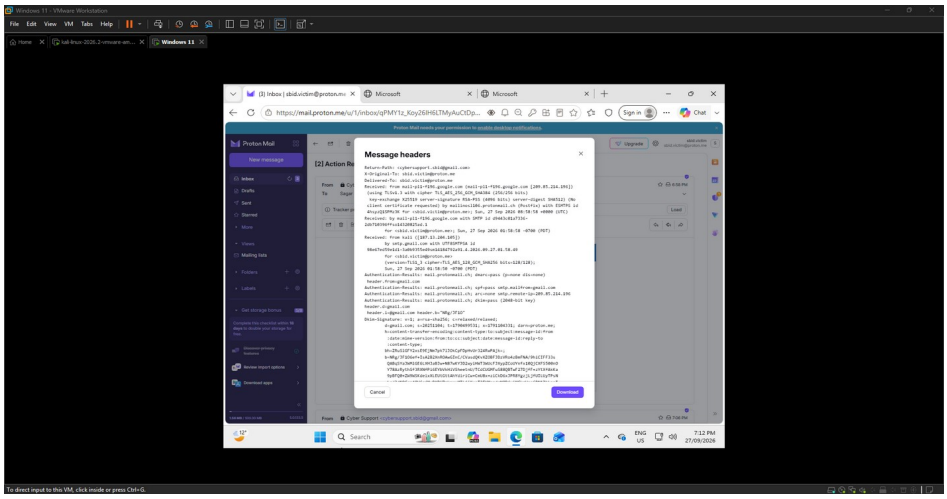


Figure 23 — Raw message headers from the received email (Proton).

Finding A — The phish passed SPF, DKIM and DMARC.

At the receiving server, Proton recorded `spf=pass`, `dkim=pass` (2048-bit, `header.d=gmail.com`) and `dmarc=pass`. Because the email was relayed through a genuine Gmail account via Google's real SMTP, every check aligns legitimately to `gmail.com`. **Authentication passing does not mean an email is safe** — an attacker abusing a free, reputable webmail account inherits its trust and evades the very filters designed to stop spoofing. This "legitimate-service abuse" is a current, real-world evasion technique.

Finding B — The attack platform leaked into the headers.

Two headers betray the tooling: `X-Mailer: gophish` (the email advertises the phishing framework), and `Message-Id: …@kali` (the attacker's host name). The first `Received:` line also shows `from kali ([187.13.204.105])`. A defender could detect or hunt on any of these indicators.

Finding C — Tool re-validation vs receiving-server verdict.

MXToolbox's header analyzer reported `DKIM Authenticated` and `DMARC Compliant` as failed. This is a **copy-paste artefact**, not a true failure: pasting a header into the tool breaks the live DKIM signature re-check (MXToolbox warns of this). The **authoritative** result is the receiving server's own `Authentication-Results` at the moment of delivery, which shows all three passing. The distinction — a tool's live re-check versus the receiving MTA's verdict — is itself an important analytical point.

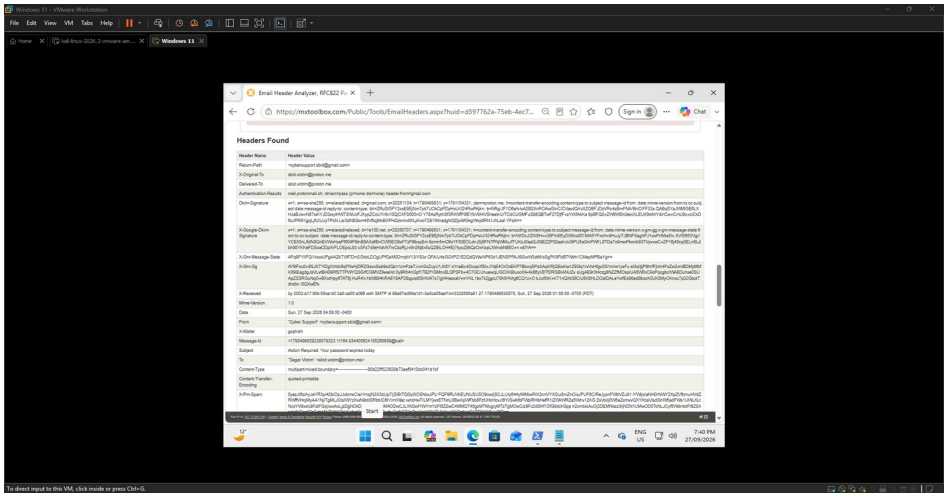


Figure 24 — MXToolbox parsed headers: X-Mailer: gophish and Message-ID ending @kali clearly exposed.

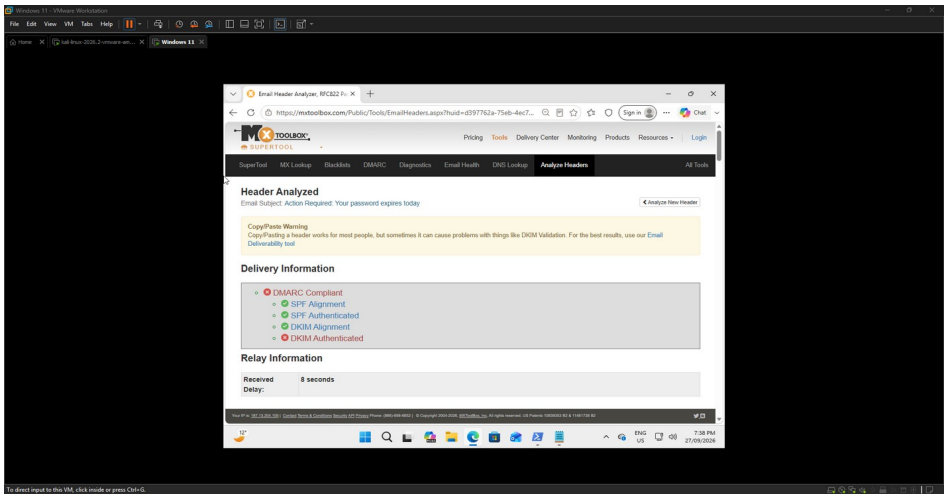


Figure 25 — MXToolbox delivery panel (note DKIM/DMARC shown failed — a copy-paste re-check artefact, not the receiving-server verdict).

8.3 Delivery path & DNS corroboration

The header analyzer reconstructs the three-hop delivery path with an 8-second total delay: `kali → smtp.gmail.com → mail-pl1-f196.google.com → mailinos1106.protonmail.ch`. Independent DNS/MX lookups verify this infrastructure is real: `proton.me` resolves to `mail.protonmail.ch (176.119.200.128)`, matching the receiving server in the headers, and `gmail.com` publishes `v=spf1 redirect=_spf.google.com` — the record that produced `spf=pass`.

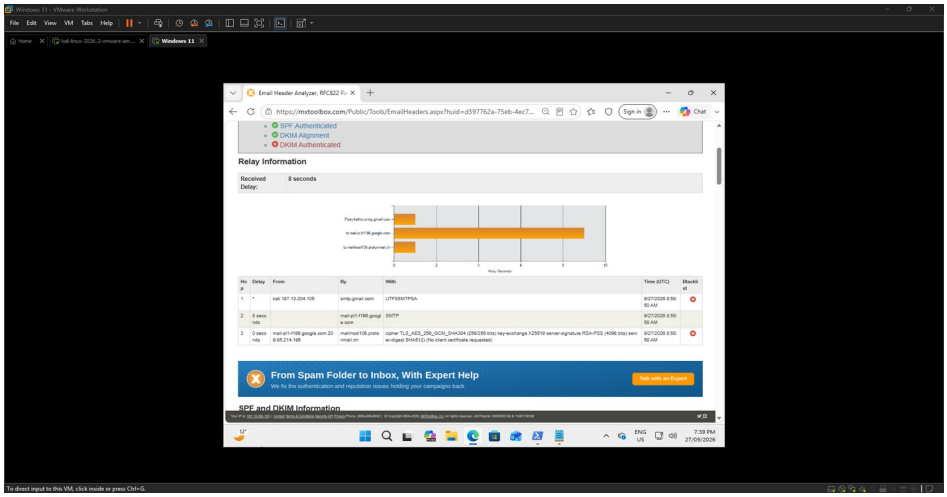


Figure 26 — Relay path and per-hop delay (kali → Gmail → Proton), independently reconstructed from the headers.

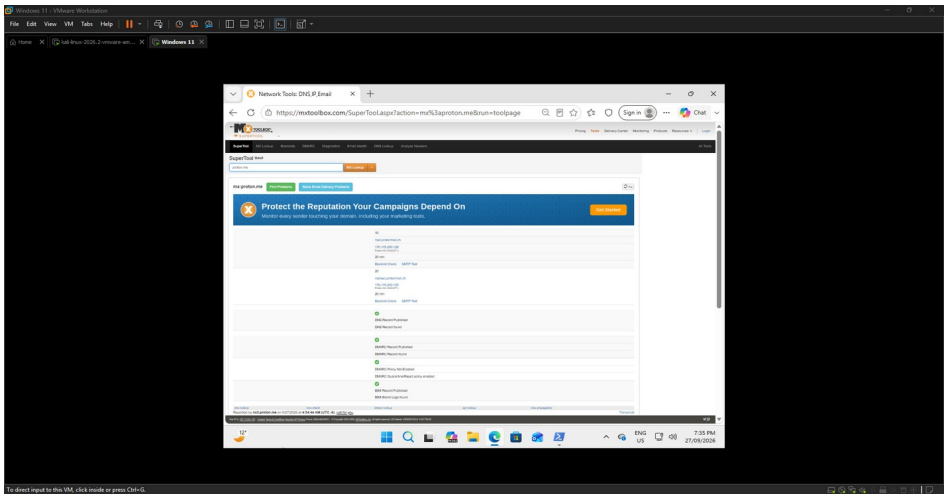


Figure 27 — MX lookup for proton.me corroborates the receiving infrastructure seen in the headers.

8.4 Victim-host artefact

On the victim endpoint, Edge browser history records the visit to `192.168.100.134` (“Sign in to your account”) followed by the redirect to the real `microsoft.com` — the host-side trace of the click. As a credential-harvesting attack (not host compromise), no Windows logon events (4624/4625) are expected; the browser history is the pertinent local artefact.

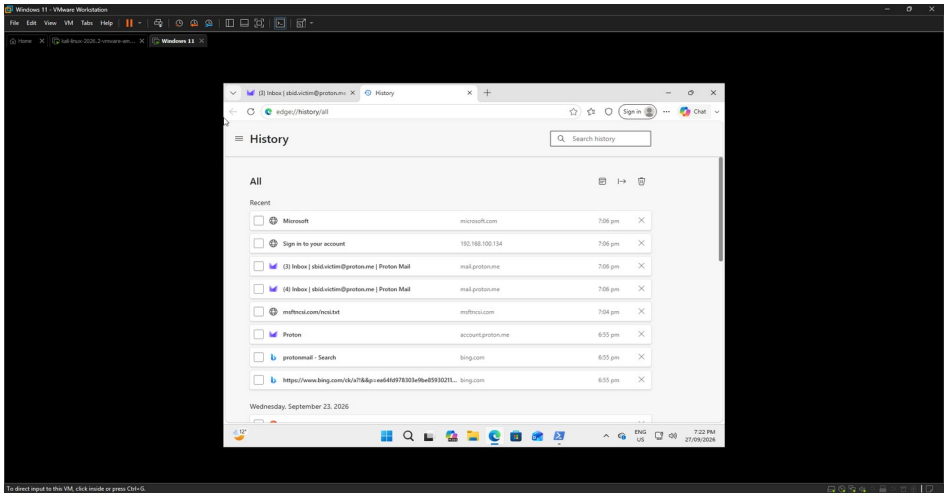


Figure 28 — Victim Edge history: visit to the fake page (192.168.100.134) then redirect to microsoft.com.

8.5 Timeline correlation & clock-skew reconciliation

Attacker-side (GoPhish) and mail-infrastructure clocks disagreed: GoPhish logged the campaign at ~05:0x (skewed Kali clock) while the mail servers and victim host agreed on the true time. The header timestamps reconcile cleanly across zones — `01:58 PDT = 08:58 UTC = 18:58 Sydney` — matching the `.eml` filename. The timeline is therefore anchored on the authoritative `Received` headers, treating GoPhish's local stamps as a known-skewed source. Reconciling skewed clocks across systems is a routine, essential forensic skill.

Time (Sydney, from headers)	Event	Evidence
18:58:50	Email accepted by Gmail SMTP from host “kali”	E1 Received chain
18:58:58	Delivered to Proton (mailinos1106.protonmail.ch)	E1 Received chain
~19:0x	Victim opens email on Windows 11	GoPhish open + Fig 15

Time (Sydney, from headers)	Event	Evidence
~19:0x	Victim clicks link → fake M365 page	Fig 16–17, browser history
~19:0x	Credentials submitted & harvested	Fig 20 (proof of harvest)

9. Findings & Indicators of Compromise

Indicator	Type	Context
cybersupport.sbid@gmail.com	Sender (abused account)	Attacker identity “Cyber Support”
187.13.204.105 (HELO “kali”)	Originating client	Recorded by Gmail as the submitting host
192.168.100.134/?rid=IUH8ofC	Phishing URL	Attacker-hosted fake M365 login
X-Mailer: gophish	Header artefact	Reveals the phishing framework
Message-ID …@kali	Header artefact	Reveals attacker host name
Action Required: Your password expires today	Subject	Password-expiry lure

Defanged: `cybersupport.sbid[@]gmail[.]com`, `hxxp://192.168.100[.]134/?rid=IUH8ofC`.

10. MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Resource Development	T1585.002 — Establish Accounts: Email	Attacker Gmail + Proton accounts created for the operation
Reconnaissance	T1598 — Phishing for Information	Password-expiry pretext crafted to elicit credentials
Initial Access	T1566.002 — Spearphishing Link	Deceptive “Keep My Password” link to fake M365 page
Credential Access	T1056.003 — Web Portal Capture	Cloned login page harvests submitted credentials

11. Incident Response Plan

Framed as if this were a genuine incident detected in an enterprise, following the standard five-phase lifecycle.

11.1 Preparation

- Deploy security-awareness training focused on password-expiry and “verify your account” lures.
- Enforce MFA everywhere so a single harvested password is insufficient for access.
- Ensure mail-gateway URL rewriting/sandboxing and a one-click “report phishing” button exist.

11.2 Detection & Analysis

- Detect on the header indicators surfaced here (`X-Mailer: gophish`, anomalous HELO names, links to bare IPs).
- Triage reported emails; extract and hash the sample; analyse headers and URLs as in Section 8.
- Assess scope: how many recipients, how many clicked, whose credentials were submitted.

11.3 Containment

- Block the sender, the phishing URL/IP and any related domains at mail gateway and proxy.
- Force-expire sessions and reset passwords for any user who submitted credentials.
- Quarantine the message from all mailboxes that received it.

11.4 Eradication & Recovery

- Confirm no mailbox rules, MFA devices or OAuth grants were added by an attacker using the credentials.
- Restore affected accounts to a known-good state; re-enable after MFA re-enrolment.

11.5 Post-Incident

- Produce a blameless write-up; feed the new IOCs into detection content.
- Run targeted awareness follow-up with the users who interacted; measure improvement.

12. Recommendations

1. **Enforce phishing-resistant MFA** — the single most effective control against credential harvesting.
2. **Deploy mail authentication + filtering** that inspects display-name spoofing and links to bare IPs, not SPF/DKIM/DMARC alone (which this attack passed).
3. **User awareness** — train staff to hover links and distrust "password expires today" urgency, as the Proton link-confirmation dialog demonstrated.
4. **Detection engineering** — alert on tooling artefacts (e.g. `X-Mailer: gophish`) and logins from unfamiliar infrastructure.
5. **Conditional access** — restrict M365 sign-in to managed devices / known locations.

13. Limitations

- Single victim and single campaign — sufficient to evidence the full chain, but not a statistical measure of susceptibility.
- DNS/MX lookups reflect records at analysis time and may change; the header analysis is tied to the captured email.
- The lab used a free webmail victim (Proton) to simulate an external recipient; an enterprise mailbox may apply additional controls.
- As a credential-harvesting scenario, no host-compromise artefacts (e.g. Windows logon events) were generated by design.

14. Conclusion

The exercise achieved its objectives end-to-end: a realistic phishing campaign was built and launched, a full victim interaction was captured through to plaintext credential harvest, and every artefact was preserved with integrity hashes and analysed. The investigation's central lesson — that a phishing email can **pass SPF, DKIM and DMARC** by abusing a legitimate mail provider — reframes email authentication as necessary but not sufficient, and points defenders toward MFA, user awareness and behaviour-based detection. The recovered platform indicators (`X-Mailer: gophish`, `@kali`) show that even a successful attack leaves a forensic trail a prepared defender can follow.

Prepared by Sagar Bidari — hands-on phishing simulation and digital forensic investigation, home lab. All findings are evidence-backed, integrity-hashed and reproducible.